Ashesi Secure Student Records Portal (ICS570 Lab 2)

Passkey (WebAuthn/FIDO2) sign-in, per-request server-side RBAC and record-ownership checks, and an AES-256-GCM demo (Part B). All data is synthetic. **Group 1:** Elise Oyilonye Kennedy-Angbo (G35532028) · Joseph Delali Kodzo Etse (G90412028) · Liza Ekua Ndede Aikins (G01322028) · Eugene Emmanuel Sewor (G25522028)

1. Stack & prerequisites

Node.js 20+ and npm. Express, `express-session` (`HttpOnly`, `SameSite=Lax`), `@simplewebauthn/server`. The frontend is static HTML/CSS/ES modules in `public/` using the native WebAuthn API with `webauthn-polyfills`, with no build step. Data is seeded from `data/seed.json` into `data/db.json`.

2. Install & run

```
npm install          # dependencies from package-lock.json
npm run reset        # reset data/db.json to the synthetic seed
npm start            # portal at http://localhost:3000 (use localhost, not 127.0.0.1)
npm test             # automated T1–T8 suite -> evidence/test-run-log.json
npm run demo:crypto  # Part B AES-256-GCM demo
# optional real-browser run + screenshots:
npm install --no-save playwright && npx playwright install chromium && node scripts/browser-evidence.mjs
```

3. Browser / authenticator setup

Use Chrome, Edge or Safari at `http://localhost:3000`, a secure context. You can use either of these:

- **Platform authenticator:** Touch ID or iCloud Keychain, Windows Hello, or a password-manager passkey.
- **Chrome DevTools virtual authenticator:** DevTools → ⋮ → More tools → **WebAuthn**. Tick *Enable virtual authenticator environment*, choose `ctap2` / `internal`, tick *resident keys* and *user verification*, then click **Add**.

4. Test accounts (`data/seed.json`)

ID	Name	Role / course	One-time enrollment code
`S001`	Ama Mensah	student, C101 (B+ / 84)	`ENROLL-S001-8492`
`S002`	Kofi Owusu	student, C101 (A- / 88)	`ENROLL-S002-3174`
`L001`	Dr. Esi Boateng	lecturer assigned to C101	`ENROLL-L001-6059`

5. Repeating T1–T8

`npm test` runs all eight. To run them by hand, run `npm run reset && npm start`. The T3–T7 probe buttons are on **Security Lab** (`#/lab`), which also opens while signed out.

Test	Steps	Expected
T1	**Set up passkey** tab → `S001` + `ENROLL-S001-8492` → **Register Passkey**	200; public key stored
T2	**Sign in** tab → `S001` → **Sign In with Passkey**	200; session created
T3	Signed in, click **Submit Tampered/Replayed Login (T3)**; it replays your real assertion, then a copy with one signature byte flipped	401 (400 with no pending challenge); no new session
T4	**Sign Out**, then **Request S001 Record (T4 / T5)**, or `curl -i http://localhost:3000/students/S001`	401
T5	As S001: **My Record** or **Request S001 Record (T4 / T5)**	200
T6	As S001: open `#/students/S002`, click **Request S002 Record (T6 ID Tamper)**, or curl `/students/S002` with the S001 `portal.sid` cookie	403
T7	As S001: **Submit Grade Update Request**, or `curl -X POST …/courses/C101/grades/S001 -d '{"grade":"A","score":100}'` with the S001 cookie	403; grade stays B+
T8	Enroll and sign in as `L001` → **Course Roster** → S001 = A / 94 → **Save**	200; grade updated

Evidence: `EVIDENCE_REPORT.md` · screenshots in `evidence/screenshots/` · `PART_B_ADDENDUM.md` · `AI_TOOLS_DECLARATION.md`